

EVIDENCE BUNDLE 5

Governance Maturity

Maturity Assessment · 12–18 Month Improvement Roadmap · Board-Level Executive Summary

GlobalHealth Connect (GHC)

Executive Governance Simulation

Prepared by: Oluwatosin Olajubu

September 2026

5.1 Current Governance Maturity Assessment

Governance Domain	Current Evidence	Current Maturity	Target
Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.	Level 1 – Ad Hoc	Level 3 – Defined
Roles & Responsibilities	Security ownership and accountability are unclear.	Level 1 – Ad Hoc	Level 3 – Defined
Risk Management	Organisation is reactive and lacks a formal proactive assessment process.	Level 1 – Ad Hoc	Level 3 – Defined
Metrics & Reporting	Technical metrics exist but are not consistently linked to business impact.	Level 2 – Initial	Level 3 – Defined
Training & Awareness	Training is mandatory, but engagement is low.	Level 2 – Initial	Level 3 – Defined
Compliance	Compliance preparation is audit-driven rather than continuously monitored.	Level 1 – Ad Hoc	Level 3 – Defined

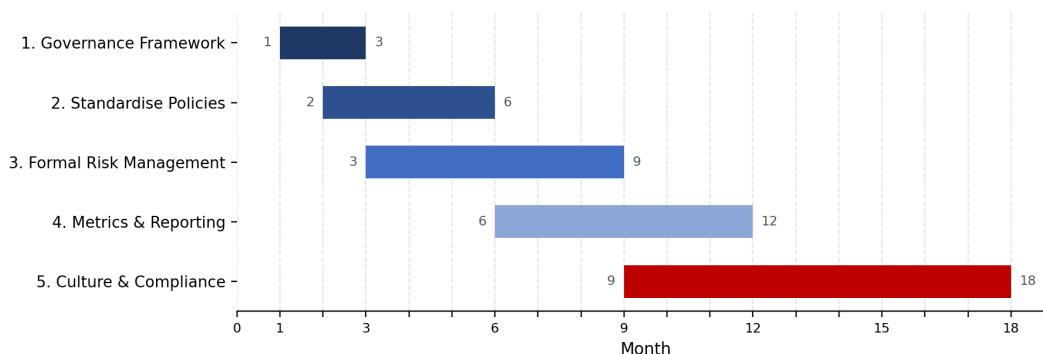
Overall Maturity Assessment

GHC's overall governance maturity is between Level 1 (Ad Hoc) and Level 2 (Initial).

Some security activities and processes exist, particularly technical metrics and mandatory training. However, these processes are inconsistent and lack sufficient integration, documentation and accountability.

The organisation's primary challenge is moving from reactive practices to defined and repeatable governance processes.

5.2 12–18 Month Governance Maturity Roadmap



Initiative 1: Establish the Information Security Governance Framework

Objective: Create a formal governance structure with defined accountability and reporting.

Key Activities:

- Approve the Information Security Charter.

- Establish the Security Steering Committee.
- Define governance roles and responsibilities.
- Implement the RACI model.
- Establish regular executive and Board reporting.

Expected Outcome: Clear governance accountability and structured oversight across the organisation.

Timeline: Months 1–3

Initiative 2: Standardise Policies and Documentation

Objective: Create a consistent and centrally governed policy framework.

Key Activities:

- Review existing policies inherited from acquisitions.
- Identify outdated or inconsistent documentation.
- Develop a central policy management process.
- Assign policy owners.
- Establish review and approval cycles.

Expected Outcome: All critical information security policies are documented, approved, current and assigned to accountable owners.

Timeline: Months 2–6

Initiative 3: Implement a Formal Security Risk Management Process

Objective: Move from reactive risk management to proactive identification and treatment of information security risks.

Key Activities:

- Develop a formal risk assessment methodology.
- Establish a security risk register.
- Define risk ownership.
- Introduce periodic risk reviews.
- Establish escalation thresholds for significant risks.

Expected Outcome: Security risks are consistently identified, assessed, treated and monitored.

Timeline: Months 3–9

Initiative 4: Improve Security Metrics and Management Reporting

Objective: Develop meaningful metrics that support executive and Board decision-making.

Key Activities:

- Define key risk and performance indicators.
- Establish reporting thresholds.
- Link technical metrics to business impact.
- Introduce monthly management reporting.
- Introduce quarterly Board reporting.

Expected Outcome: Decision-makers receive consistent and meaningful information about security performance and risk.

Timeline: Months 6–12

Initiative 5: Strengthen Security Culture and Compliance Monitoring

Objective: Improve employee engagement and transition from audit-driven compliance to continuous monitoring.

Key Activities:

- Improve awareness training content.
- Introduce targeted training based on risk.
- Conduct awareness simulations and assessments.
- Establish compliance monitoring activities.
- Track remediation of identified compliance gaps.

Expected Outcome: Improved security awareness, stronger employee engagement and continuous visibility of compliance obligations.

Timeline: Months 9–18

5.3 Roadmap Summary

Period	Priority Focus
Months 1–3	Governance structure, Charter, RACI and Security Steering Committee
Months 2–6	Policy and documentation standardisation
Months 3–9	Formal risk management process
Months 6–12	Metrics, reporting and management oversight
Months 9–18	Security culture and continuous compliance monitoring

5.4 Board Executive Summary

GlobalHealth Connect currently operates at an overall governance maturity level between Ad Hoc and Initial. While some information security activities exist, governance processes are inconsistent, accountability is unclear and security risk management remains largely reactive.

The proposed 12–18 month roadmap is designed to move GHC to at least Level 3 (Defined) maturity across all governance domains. The roadmap prioritises the establishment of formal governance structures, standardised policies, proactive risk management, meaningful Board reporting and continuous compliance monitoring.

Achieving this level of maturity is strategically important because GHC is expanding, integrating acquisitions and investing in new technologies. Without stronger governance, the organisation may struggle to manage increasing security, regulatory and operational risks. The roadmap therefore provides a practical foundation for sustainable growth, customer trust and long-term organisational resilience.

Conclusion

The governance challenges facing GlobalHealth Connect demonstrate that information security cannot be effectively managed through isolated technical activities alone. As the organisation grows, information security must become an integrated governance function supported by the Board, executive management and operational teams.

The proposed governance blueprint establishes clear accountability and reporting relationships. The Information Security Charter provides a formal mandate for the security programme. Board-level reporting ensures that significant risks and trends are communicated in business-focused terms. The Security Steering Committee provides a mechanism for resolving cross-functional conflicts, while the maturity roadmap establishes a practical path towards more consistent and measurable governance.

Together, these initiatives will help GHC move from a reactive security model towards a structured, business-aligned and continuously improving information security governance programme.